

MODULE 5 Core Security Concepts

Phase	Duration
Phase 1	Week 2

Module Overview

This module builds on the foundational cybersecurity awareness established in Module 1 and dives deeper into the core security concepts that every cybersecurity professional must master. Students will explore access control models, authentication mechanisms, cryptography fundamentals, security policies, and risk management principles. These concepts underpin virtually every security technology and practice encountered throughout the remaining 12-week program and in professional security roles.

Learning Objectives

By the end of this module, students will be able to:

- Explain the core principles of access control and describe common access control models
- Differentiate between authentication, authorization, and accounting (AAA)
- Describe how multi-factor authentication (MFA) strengthens identity verification
- Explain fundamental cryptographic concepts including symmetric and asymmetric encryption
- Define key risk management terms and describe the risk management process
- Identify the components of a security policy and explain its organizational role
- Understand the concept of defense-in-depth and layered security strategies

Key Concepts & Terminology

Access Control

Access control is the selective restriction of access to a place or other resource, ensuring that only authorized users can access specific systems, data, or services. It is one of the most fundamental concepts in cybersecurity.

Access Control Models

Different environments require different approaches to managing who can access what resources:

Access Control Model	Description & Use Case
Discretionary Access Control (DAC)	Resource owners decide who can access their resources. Common in standard OS file systems (e.g., Windows, Linux permissions). Flexible but relies on user responsibility.

Mandatory Access Control (MAC)	The system enforces access based on classification labels (e.g., Top Secret, Confidential). Used in government and military environments. Users cannot override policies.
Role-Based Access Control (RBAC)	Access is granted based on a user's role within an organization (e.g., Admin, Analyst, Manager). Widely used in corporate environments for scalability.
Attribute-Based Access Control (ABAC)	Access decisions based on multiple attributes: user department, device type, time of day, location. Most flexible but complex to implement.
Rule-Based Access Control	Access determined by predefined rules set by administrators, such as firewall ACLs allowing or denying traffic based on IP and port.

Authentication, Authorization & Accounting (AAA)

The AAA framework is a security architecture used to control access to computer resources, enforce policies, and audit usage.

AAA Component	Definition & Examples
Authentication	Verifying the identity of a user or device. Examples: passwords, PINs, biometrics, smart cards, digital certificates.
Authorization	Determining what an authenticated user is permitted to do. Examples: file permissions, network access rules, application feature access.
Accounting	Tracking and recording user activities for auditing and compliance. Examples: login logs, file access records, command history.

Authentication Factors

Authentication methods are categorized into three factor types. Combining multiple factors creates Multi-Factor Authentication (MFA):

Factor Type	Description & Examples
Something You Know	Knowledge-based: passwords, PINs, security questions, passphrases
Something You Have	Possession-based: hardware token, smart card, mobile authenticator app (e.g., Google Authenticator), SMS code
Something You Are	Inherence-based (biometrics): fingerprint, facial recognition, retinal scan, voice recognition

Why Multi-Factor Authentication (MFA) Matters:

- Passwords alone are easily compromised through phishing, brute force, or credential stuffing

- MFA adds a second verification layer even if a password is stolen, an attacker cannot authenticate without the second factor
- Industry standard for protecting privileged accounts, remote access, and sensitive systems
- Common MFA implementations: SMS one-time codes, authenticator apps, hardware tokens, push notifications

Cryptography Fundamentals

Cryptography is the practice of securing information by transforming it into an unreadable format, ensuring confidentiality, integrity, and authenticity of data. It is the mathematical foundation of modern cybersecurity.

Core Cryptographic Concepts

Term	Definition
Plaintext	Original, readable data before encryption
Ciphertext	Data after encryption — unreadable without the decryption key
Encryption	The process of converting plaintext to ciphertext using an algorithm and key
Decryption	The reverse process of converting ciphertext back to plaintext
Key	A piece of data (a string of bits) that determines the output of a cryptographic algorithm
Hash Function	A one-way function that converts data into a fixed-length digest; used for integrity verification (e.g., MD5, SHA-256)
Digital Signature	A cryptographic mechanism that proves authenticity and non-repudiation of a message or document

Symmetric vs. Asymmetric Encryption

Type	How It Works	Key Characteristics
Symmetric Encryption	Same key used for both encryption and decryption	Fast, efficient for large data. Key distribution is a challenge. Examples: AES-256, 3DES, ChaCha20
Asymmetric Encryption	Public key encrypts; private key decrypts (or vice versa for signatures)	Slower but solves key distribution. Enables secure key exchange. Examples: RSA, ECC, Diffie-Hellman
Hybrid Approach	Asymmetric encryption used to securely exchange a symmetric session key	Used in TLS/HTTPS, SSH, VPNs - combines speed with security

Real-World Example: HTTPS

When you visit a secure website (https://), your browser and the web server perform a TLS handshake: asymmetric encryption securely exchanges a symmetric session key, and all subsequent communication is encrypted using that faster symmetric key. This is why HTTPS is both secure and fast.

Risk Management Fundamentals

Risk management is the process of identifying, assessing, and prioritizing risks, then applying resources to minimize their impact. It is the foundation of all security program decision-making.

Core Risk Terminology

Term	Definition
Asset	Anything of value that needs protection: data, systems, people, facilities, reputation
Threat	A potential event or action that could harm an asset (e.g., malware, natural disaster, insider attack)
Vulnerability	A weakness in a system or process that a threat can exploit (e.g., unpatched software, weak passwords)
Risk	The likelihood that a threat will exploit a vulnerability and the resulting impact. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
Exploit	A method or tool used to take advantage of a vulnerability
Control / Safeguard	A measure put in place to reduce risk (e.g., firewall, encryption, security awareness training)
Residual Risk	The remaining level of risk after security controls have been applied

Risk Response Strategies

Strategy	Description & Example
Risk Avoidance	Eliminate the activity that creates the risk. Example: Deciding not to store sensitive customer credit card data.
Risk Mitigation	Reduce the likelihood or impact of the risk. Example: Installing a patch to fix a known vulnerability.
Risk Transference	Transfer the financial impact to a third party. Example: Purchasing cybersecurity insurance.
Risk Acceptance	Acknowledge the risk and choose to operate without further controls. Appropriate when mitigation cost exceeds potential loss.

Security Policies & Governance

A security policy is a formal document that defines an organization's security objectives, rules, and responsibilities. Policies are the foundation of an organization's security program — they guide technical controls, user behavior, and incident response.

Types of Security Documents

Document Type	Purpose & Example
Policy	High-level statement of management intent and direction. Example: Acceptable Use Policy (AUP) stating company devices may not be used for illegal activities.
Standard	Specific mandatory requirements that support a policy. Example: All passwords must be at least 12 characters, include uppercase, lowercase, number, and symbol.
Procedure	Step-by-step instructions for performing a task. Example: How to report a suspected phishing email.
Guideline	Recommended (non-mandatory) best practices. Example: Suggestions for organizing files securely on shared drives.
Baseline	Minimum security configuration required for systems. Example: All servers must have automatic security updates enabled.

Common Security Policies Every Organization Should Have:

- Acceptable Use Policy (AUP) – Rules for appropriate use of organizational technology resources
- Password / Credential Management Policy – Requirements for password complexity, rotation, and storage
- Incident Response Policy – Process for detecting, reporting, and responding to security incidents
- Data Classification Policy – Defines how data should be categorized and handled (Public, Internal, Confidential, Restricted)
- Remote Access Policy – Security requirements for connecting to organizational systems remotely
- Bring Your Own Device (BYOD) Policy – Rules governing employee-owned devices used for work purposes

Defense-in-Depth

Defense-in-depth is a security strategy that employs multiple layers of controls so that if one layer fails, others remain in place to protect assets. Relying on a single control (e.g., just a firewall) leaves an organization vulnerable when that control is bypassed.

Security Control Categories

Control Type	Description & Examples
Preventive	Stop an attack before it succeeds. Examples: firewalls, access controls, encryption, security awareness training
Detective	Identify an attack in progress or after the fact. Examples: IDS/IPS, SIEM alerts, log monitoring, antivirus scanning
Corrective	Reduce the impact of an attack and restore systems. Examples: patch management, incident response, backups and recovery
Deterrent	Discourage attackers from attempting an attack. Examples: warning banners, security cameras, prosecution policies
Compensating	Alternative controls when primary controls cannot be implemented. Examples: enhanced monitoring when a legacy system cannot be patched

Defense-in-Depth in Practice

Protecting a database with sensitive records requires multiple layers: network firewall (prevents external scanning), application firewall (blocks injection attacks), access controls (only authorized users), database encryption (protects data if stolen), activity logging (detects unauthorized queries), and backups (enables recovery). Each layer addresses a different threat vector.